cveResponderAI: Local AI for CVE Triage and Incident Response

Emrah Yıldırım (emr4h)

2026-03-11

Version: 1.0

Date: 2026-03-11

Repository: https://github.com/emr4h/cveResponderAI

Local AI for CVE triage, PoC analysis, MITRE ATT&CK mapping, asset correlation, and incident response planning.

1. Abstract / Executive Summary

In the high-stakes environment of Incident Response (IR), analysts are constantly racing against time. When a new critical Common Vulnerabilities and Exposures (CVE) identifier is published, defenders must quickly understand the vulnerability, review public exploit activity, compare affected products with internal assets, and decide on detection and mitigation steps. That workflow is usually fragmented across multiple sites and tools.

cveResponderAI is an open-source, local-first security tool built to solve that problem. It combines public threat intelligence sources such as the National Vulnerability Database (NVD) and the CISA Known Exploited Vulnerabilities (KEV) catalog with locally hosted Large Language Models (LLMs) through Ollama. The key design goal is simple: the AI reasoning layer runs locally, so sensitive prompts, internal inventory data, and exploit analysis do not need to leave the analyst machine for cloud AI services. Optional internet-based enrichment can be used for public news and PoC discovery, but the model execution itself remains local and cloud-free.

The result is a practical analyst workflow that can map CVEs to MITRE ATT&CK, explain PoC code, correlate affected products with asset inventory, and generate structured detection and mitigation guidance from a single interface.

At a Glance

- **Local-first AI:** Model execution runs through local Ollama models instead of cloud AI services
- **Operator workflow:** One interface for CVE triage, PoC review, ATT&CK mapping, and IR planning
- **Asset awareness:** Affected products can be compared with internal inventory
- **Public enrichment:** News and GitHub PoC discovery add optional external context
- **Defensive output:** The tool generates structured detection and mitigation guidance

2. Introduction & Motivation

When a zero-day or high-impact vulnerability drops, pressure on SOC and IR teams rises immediately. Analysts are expected to move from raw CVE publication to operational response in a very short time window. In practice, that process is often slowed by three problems:

1. **Context switching:** Analysts move between NVD, CISA, GitHub, vendor advisories, and news sites to build one usable picture.
2. **Analysis paralysis:** Turning raw exploit code into action items for SIEM, EDR, and patching teams requires time and reverse-engineering skill.
3. **Privacy risk:** Public LLM platforms are useful for summarization, but sending internal asset data, log fragments, or exploit samples to cloud AI may violate policy.

Motivation: cveResponderAI was built as one cohesive local-first dashboard that keeps the reasoning layer on the analyst machine while still helping the operator collect public context, explain exploit logic, and produce defensive outputs faster.

---

3. Core Concept & Architecture

The architecture of cveResponderAI is intentionally lightweight: a Python Flask backend, a vanilla JavaScript frontend, and a local Ollama runtime. There is no heavy frontend build chain and no dependence on external cloud AI APIs.

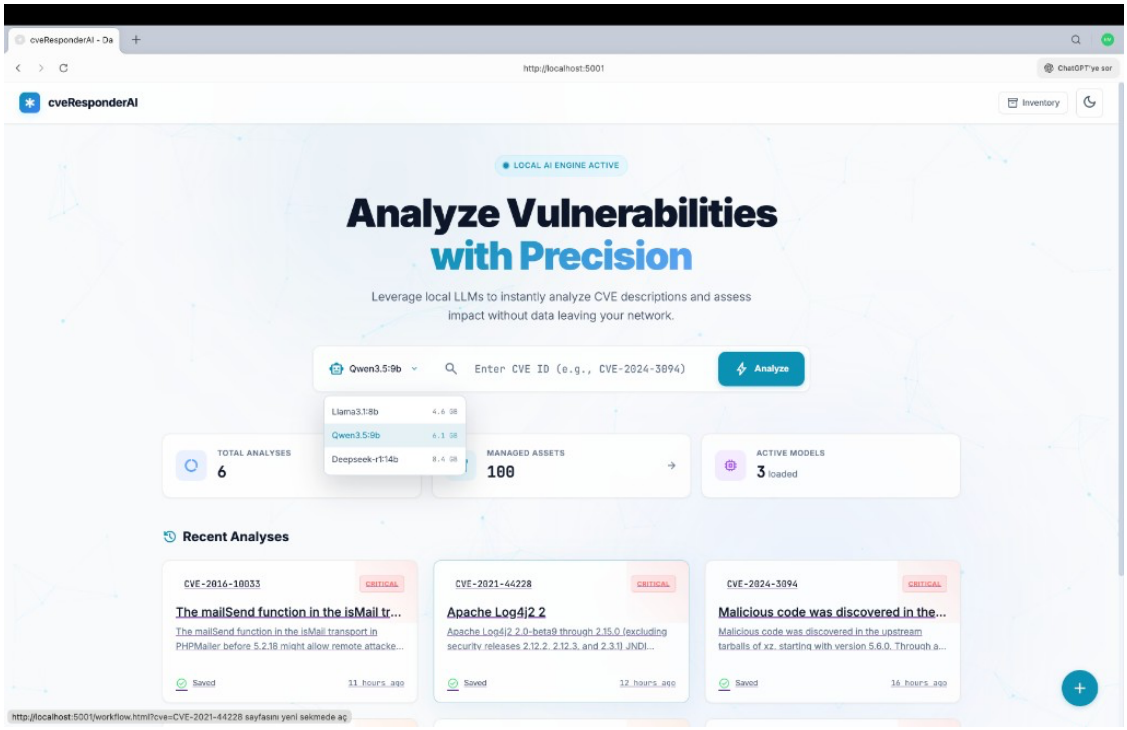
3.1 Architecture Flow

1. **CVE ingestion:** The analyst enters a CVE ID. The backend fetches NVD data and checks KEV status.
2. **Optional public enrichment:** The system can search for public PoC repositories and public security news related to the CVE.
3. **Prompt orchestration:** CVE description, CVSS, product data, PoC status, MITRE candidates, inventory context, and news snippets are assembled into structured prompts.
4. **Local model execution:** The selected Ollama model performs the reasoning locally on the analyst host.
5. **Recovery and normalization:** If the model does not return valid JSON, the backend falls back to a text recovery layer that reconstructs usable defensive output.

This model keeps the core AI workflow local while still allowing public-source enrichment when the user wants broader context.

3.2 Operator Entry Point

The landing page is designed for fast triage. The analyst can choose any locally available Ollama model, enter a CVE, and begin analysis from a single screen.



DASHBOARD WITH MODEL SELECTION AND CVE ANALYSIS ENTRY POINT

Figure 1. Dashboard and local model selection.

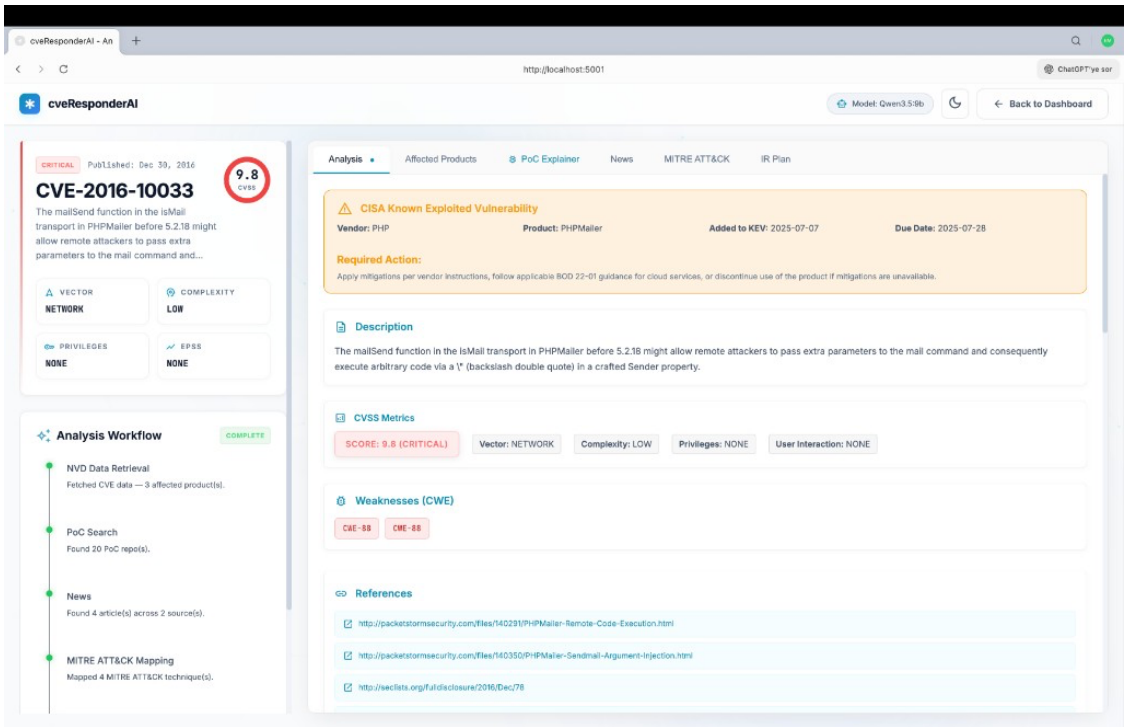
4. Product Workflow and Feature Deep Dive

4.1 End-to-End Workflow View

The main workflow page organizes the analysis into practical response stages: basic CVE details, affected products, PoC discovery, news, MITRE ATT&CK mapping, and the IR plan. This is important for Black Hat Arsenal because the tool is not just a backend utility; it is a live operator-facing workflow built for demo and day-to-day use.

4.1.1 Workflow Summary

1. Start from the dashboard and choose a local Ollama model
2. Enter a CVE and retrieve NVD plus KEV context
3. Review affected products and compare with asset inventory
4. Inspect public PoC repositories and optional code analysis
5. Add public news context for broader situational awareness
6. Map the CVE to MITRE ATT&CK techniques
7. Generate a practical IR plan for detection and mitigation

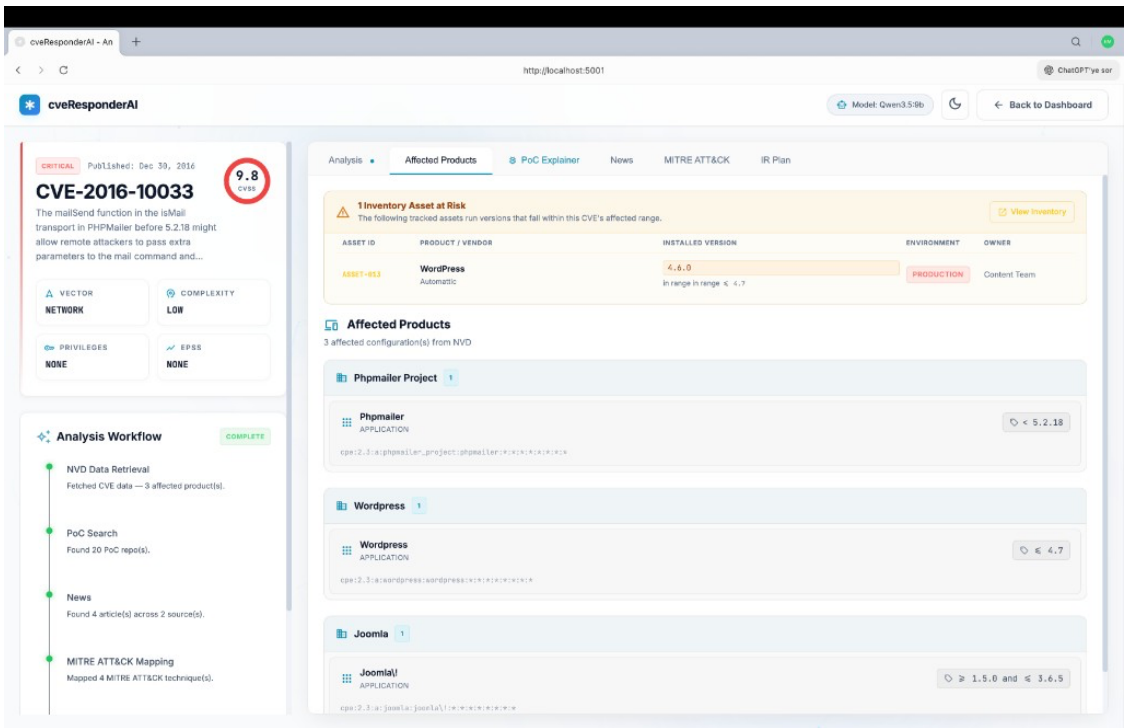


WORKFLOW OVERVIEW FOR A FULL CVE ANALYSIS

Figure 2. Workflow overview with KEV and CVSS context.

4.2 Affected Products and Asset Correlation

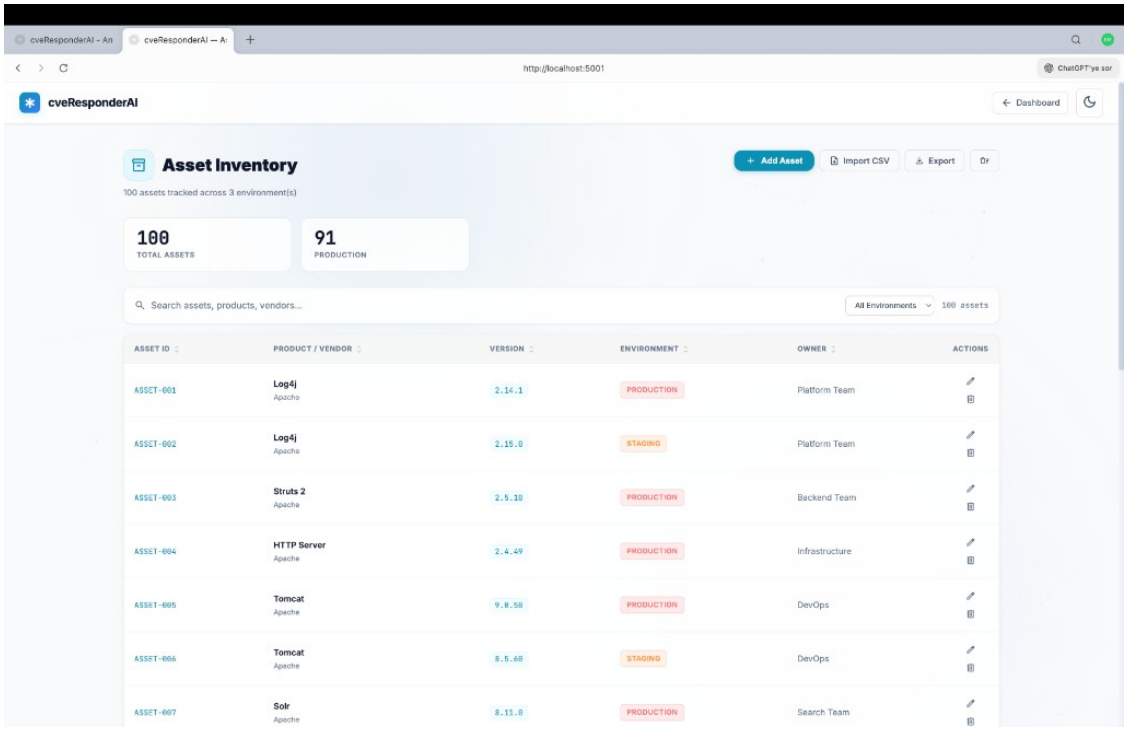
NVD data includes CPE 2.3 strings that are often hard to interpret quickly during response. cveResponderAI parses those product entries into readable product cards and compares them with local asset inventory data where available. This gives the analyst a faster answer to the most practical question in triage: “Does this hit us?”



AFFECTED PRODUCT MATCHING WITH INVENTORY RISK BANNER

Figure 3. Affected product match with inventory risk.

The broader asset inventory view gives teams a simple way to maintain local records that can later be used during CVE triage. That makes the workflow more operational than a basic CVE lookup tool.

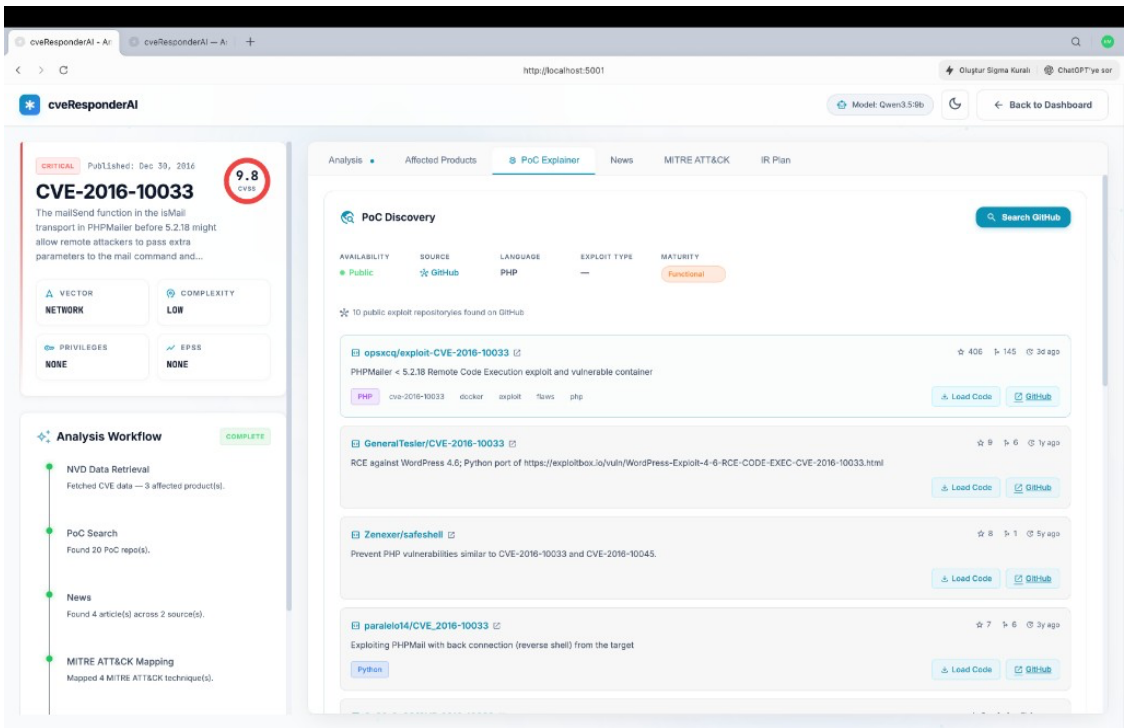


ASSET INVENTORY OVERVIEW

Figure 4. Asset inventory overview.

4.3 PoC Discovery and Public Exploit Awareness

When public exploit repositories exist, analysts need fast visibility into them. The PoC discovery module searches GitHub for CVE-related repositories and summarizes results directly in the workflow. This is optional public enrichment, but it saves time and keeps the next step close to the analyst: exploit understanding.



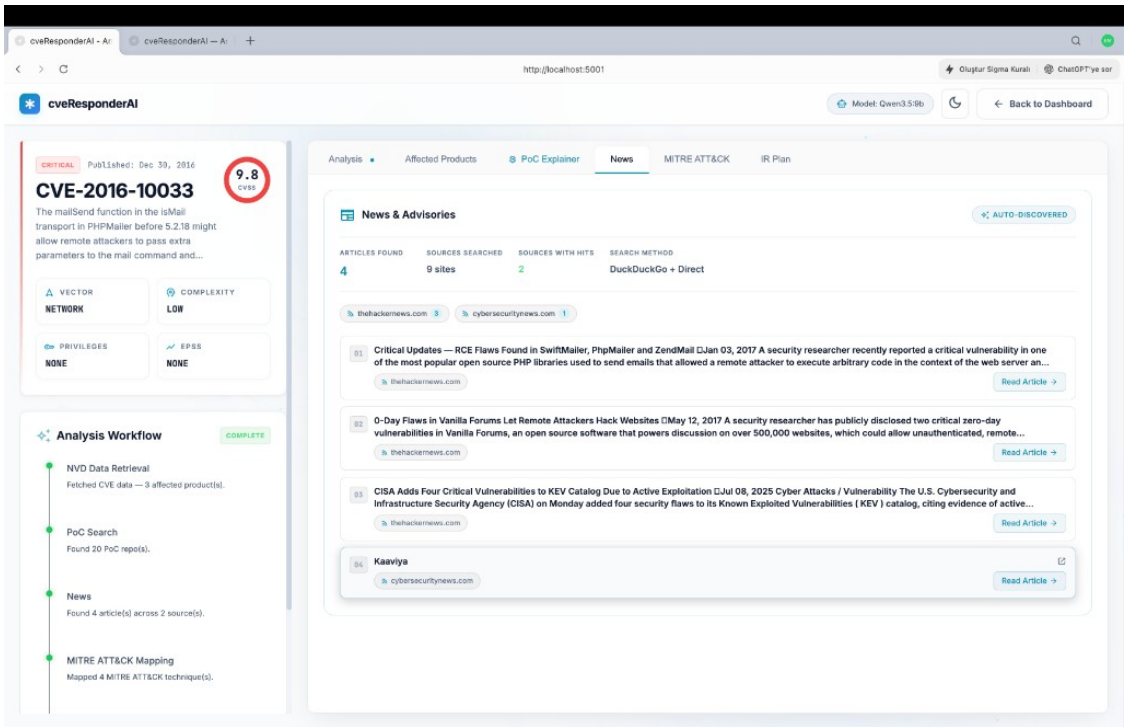
PoC DISCOVERY SCREEN WITH GITHUB REPOSITORY RESULTS

Figure 5. PoC discovery from public repositories.

4.4 OSINT and News Aggregation

Threat context changes quickly once active exploitation starts. The news module searches public security sources and collects articles relevant to the selected CVE. Those findings are useful both for the human analyst and for improving the prompt context sent to the local model.

To keep the workflow responsive, cveResponderAI queries multiple public sources in parallel, deduplicates overlapping results, and compresses the most relevant intelligence into a short context block for the model. This fresh OSINT helps the system generate guidance based not only on the CVE text, but also on how the issue is being discussed and exploited in the wild.

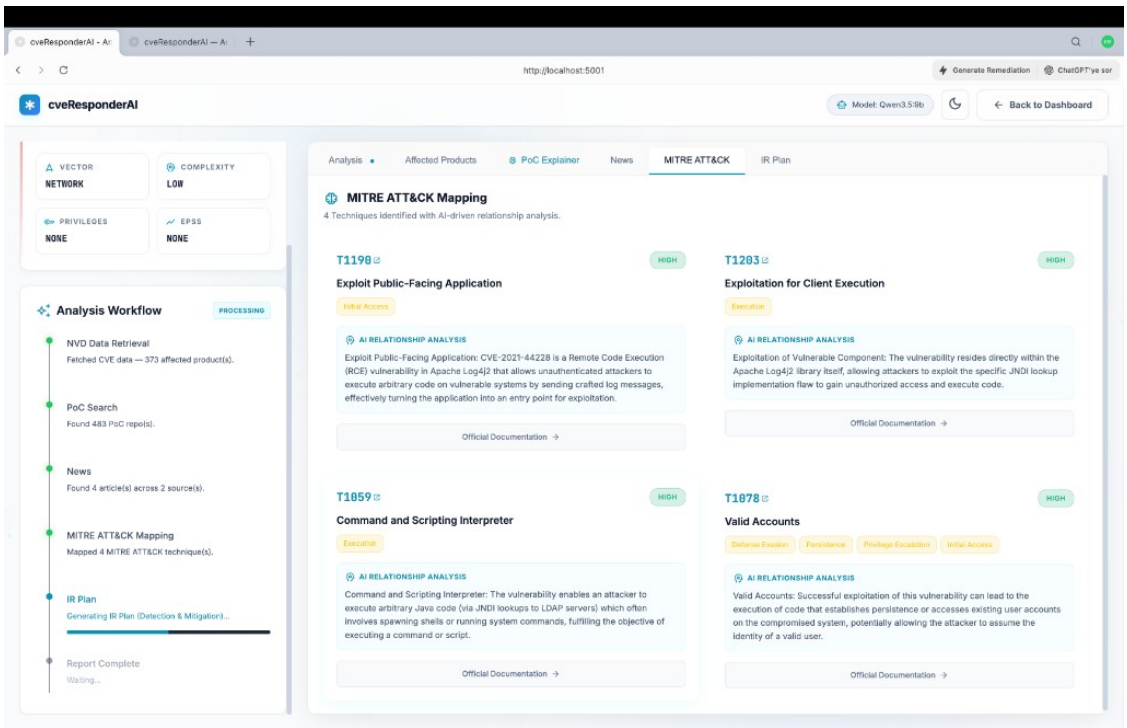


NEWS AND ADVISORIES MODULE

Figure 6. News and advisory aggregation.

4.5 MITRE ATT&CK Mapping with AI Justification

Understanding the tactical meaning of a CVE matters during incident response. cveResponderAI ships with a local `DATA/MITRE-ATTACK.JSON` dataset and uses the local model to suggest ATT&CK techniques with short justifications. This helps analysts move from product-level weakness to attacker behavior more quickly.



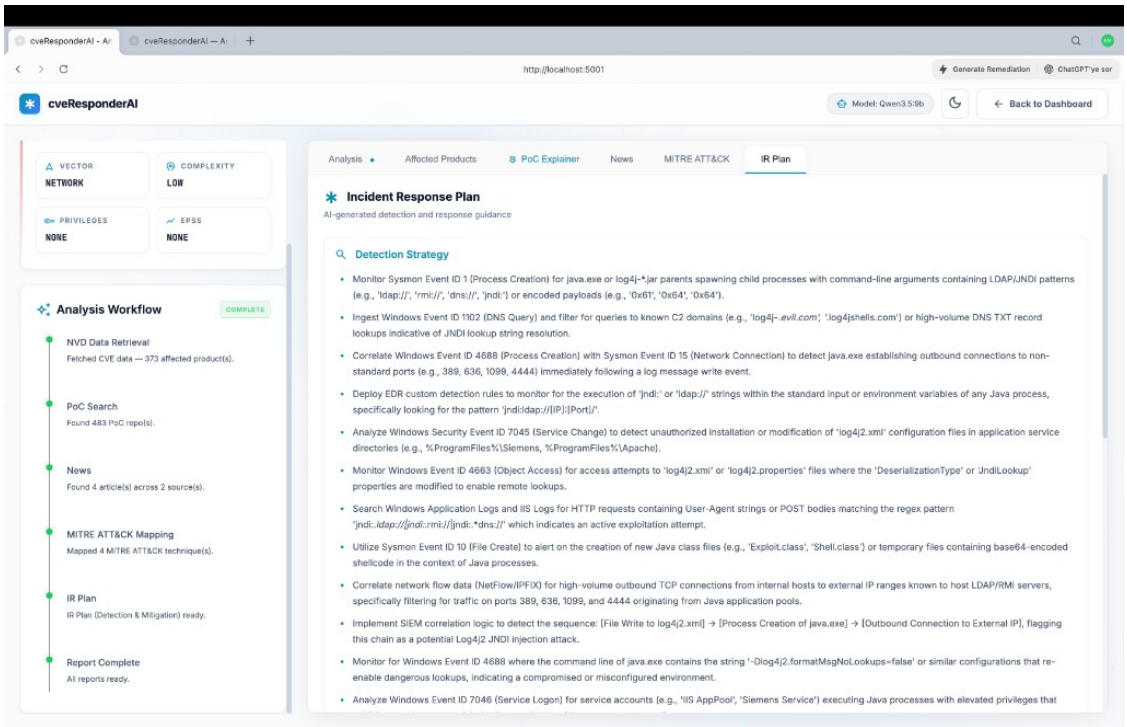
MITRE ATT&CK MAPPING WITH AI RELATIONSHIP ANALYSIS

Figure 7. MITRE ATT&CK mapping and AI rationale.

4.6 Automated IR Planning (Detection and Mitigation)

The core capability of cveResponderAI is the generation of a structured Incident Response Plan. The backend aggregates CVE description, severity, affected products, PoC context, MITRE mapping, and news context into a targeted prompt for the local model.

The planner packages all of that context into a structured request and asks the local model for a strict JSON response. The system specifically asks for 8-12 concrete detection ideas and 8-12 mitigation steps so the output is actionable for defenders, not just descriptive. If a model returns imperfect formatting, the recovery layer normalizes the result into usable detection and mitigation arrays.



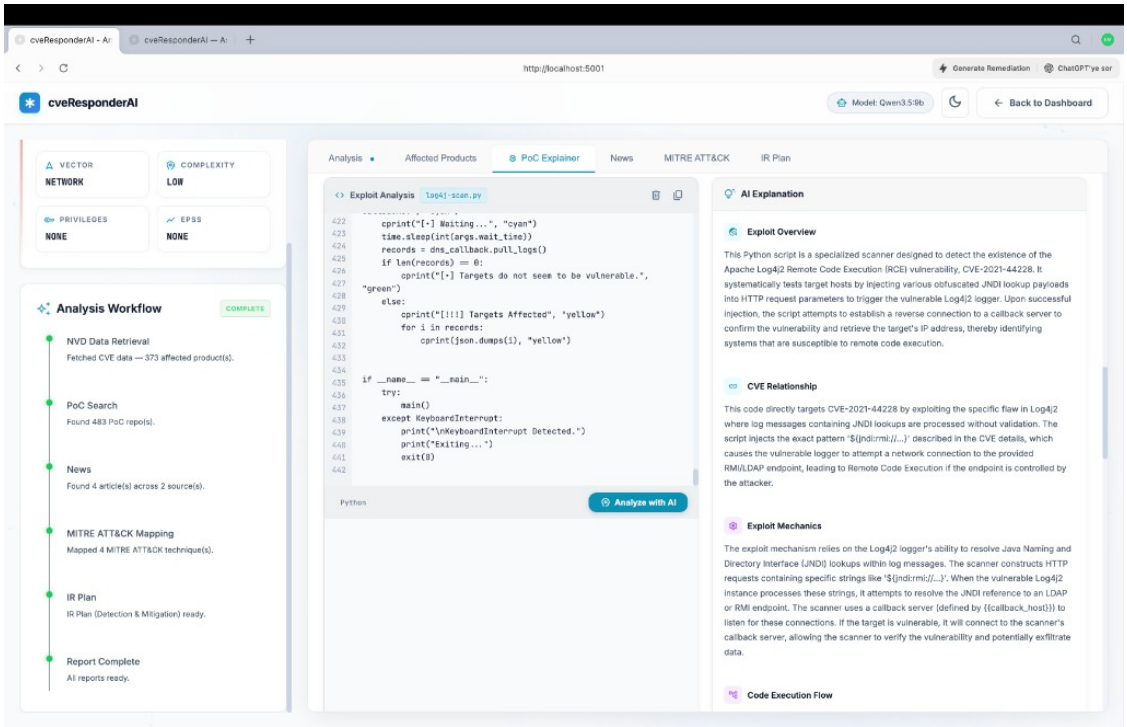
IR PLAN VIEW WITH GENERATED DETECTION STRATEGY

Figure 8. Incident response plan output.

4.7 PoC Explainer and Attack Path Analysis

One of the most practical modules is the PoC Explainer. Analysts can paste exploit code into the interface and ask a local model to explain what it does. This is valuable when exploit code is long, unfamiliar, or partially obfuscated.

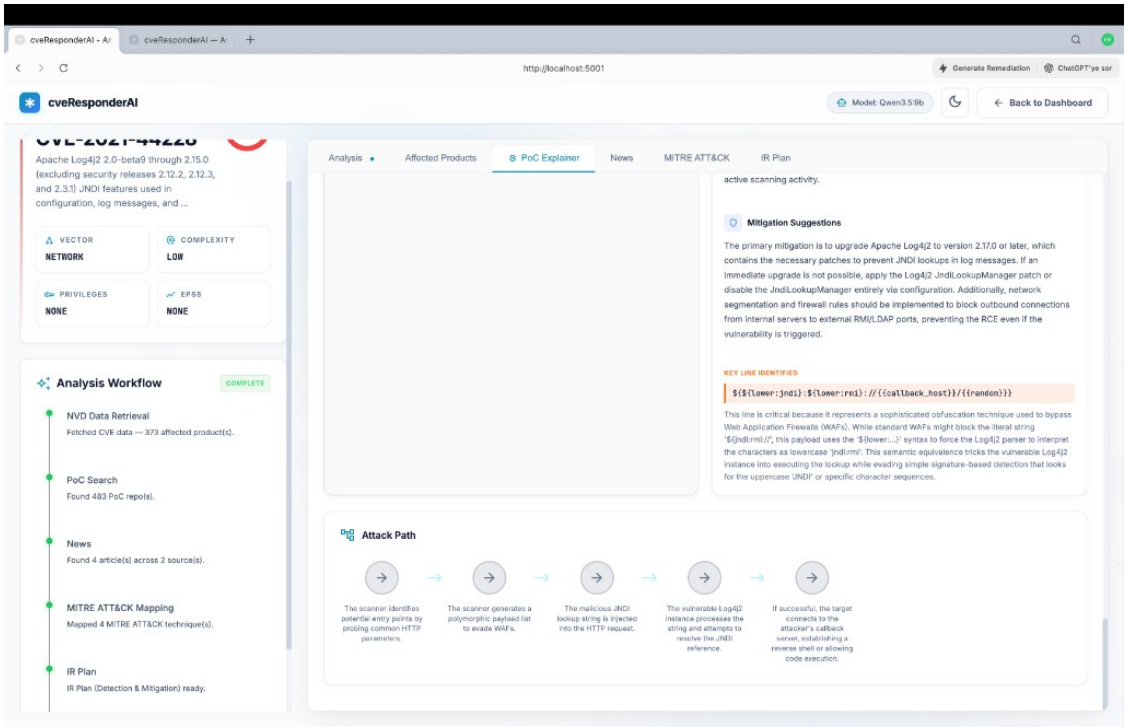
The exploit analysis output focuses on human-readable sections such as exploit overview, CVE relationship, exploit mechanics, and code execution flow. This helps bridge the gap between reverse engineering and operational response.



EXPLOIT ANALYSIS VIEW INSIDE THE POC EXPLAINER

Figure 9. PoC exploit analysis view.

The attack path visualization then turns exploit logic into a simple step-by-step flow that is easier to communicate to defenders, incident managers, and other teams.



ATTACK PATH AND MITIGATION SUGGESTIONS

Figure 10. Attack path and mitigation output.

4.8 LLM Communication and Resilience Layer

Local LLMs, especially smaller quantized models, do not always return perfectly structured output. cveResponderAI addresses this with a recovery layer that strips model-specific reasoning blocks, detects key defensive sections, and reconstructs normalized arrays for detection and mitigation content.

This matters in practice because an Arsenal demo should show a tool that is resilient, not one that only works under ideal prompt conditions.

5. Technical Implementation & Requirements

5.1 Tech Stack

- **Backend:** Python 3.x, Flask, Requests
- **Frontend:** Vanilla JavaScript, CSS3
- **AI Runtime:** Ollama API on `LOCALHOST:11434`
- **Threat Data:** NVD API v2, CISA KEV catalog, optional public news and GitHub PoC search
- **Local Dataset:** `DATA/MITRE-ATTACK.JSON`

5.2 Recommended Models

cveResponderAI dynamically queries the Ollama `/API/TAGS` endpoint so the operator can work with any locally installed model. The following models are recommended:

1. **qwen3.5:9b**: Main choice for balanced speed and reliable structured output
2. **deepseek-r1:14b**: Strong option for the PoC Explainer and reasoning-heavy code analysis
3. **llama3.1:8b**: Good general model for quick triage and broad security guidance

5.3 Installation and Runtime

The tool is designed to be easy to run in a lab or analyst workstation environment:

```
DOWNLOAD FROM "OLLAMA.COM"
Pull model;

ollama pull qwen3.5:9b (optional but recommended)
ollama pull deepseek-r1:14b
ollama pull llama3.1:8b
ollama serve

GIT CLONE HTTPS://GITHUB.COM/EMR4H/CVERESPONDERAI.GIT
CD CVERESPONDERAI
PIP INSTALL -R REQUIREMENTS.TXT
PYTHON3 SERVER.PY
```

5.4 Platform and Hardware Notes

- **Platforms:** Best suited for macOS, Linux, or Windows systems capable of running Python and Ollama
- **Hardware:** For models under 10B parameters, 16 GB RAM is a reasonable baseline; Apple Silicon and dedicated GPUs improve latency
- **Model choice:** Users can choose any locally installed Ollama model, depending on performance and reasoning needs

5.5 Operational Scope and Limitations

- The AI reasoning pipeline is local and cloud-free through Ollama
- Public-source enrichment such as news and GitHub PoC discovery requires internet access
- Quality depends on the selected local model and available system resources
- Generated detection and mitigation content is intended to accelerate analyst work, not replace validation in production environments

6. Real-World Use Case: Investigating Log4Shell (CVE-2021-44228)

Scenario: A SOC analyst receives an alert regarding anomalous outbound LDAP traffic that may indicate a Log4Shell attempt.

1. **Triage:** The analyst enters `CVE-2021-44228` into cveResponderAI and reviews severity, references, and affected products.
2. **Exposure check:** The affected products tab is used to compare vulnerable versions with local inventory records.
3. **Context enrichment:** Public PoC repositories and public news coverage are reviewed for exploit trends and available code.
4. **MITRE mapping:** The tool maps the vulnerability to ATT&CK techniques that support hunting and defensive context.
5. **IR generation:** The local model generates detection ideas such as monitoring JNDI payload patterns and suspicious outbound LDAP or RMI behavior.
6. **PoC evaluation:** If the analyst pastes exploit code or a suspicious sample into the PoC Explainer, the local model can explain the attack path without sending the code to a cloud AI provider.

This use case shows the practical value of cveResponderAI: it turns a single CVE identifier into a connected local workflow for exposure review, exploit understanding, ATT&CK framing, and defensive action.

---

7. Black Hat Arsenal Positioning and Demo Plan

cveResponderAI matches the spirit of Black Hat Arsenal by presenting a practical, open-source, and technically detailed defensive workflow for real operators.

- **Defensive focus:** It uses LLMs to support detection, triage, and mitigation instead of offensive automation.
- **Accessibility:** It allows teams to choose their own local Ollama models rather than depend on commercial cloud AI subscriptions.
- **Privacy core:** It keeps the reasoning layer on local infrastructure, so sensitive analysis stays under operator control.
- **Operational relevance:** It combines CVE data, product exposure, exploit awareness, ATT&CK mapping, and IR planning in one interface.

Planned Arsenal Demo Flow

The live Arsenal demo will follow the same workflow described in this paper:

1. Select a local Ollama model from the dashboard
2. Analyze a high-impact CVE
3. Review KEV status, references, and affected products
4. Show asset inventory correlation
5. Discover public PoC repositories and inspect exploit logic locally
6. Review news context and MITRE ATT&CK mapping
7. End with the generated IR plan

A full workflow demo video is planned and will be published in the repository under `DEMO/`.

---

8. Conclusion

In an era where vulnerabilities can become operational emergencies within hours, defensive speed matters. **cveResponderAI** gives Incident Responders a local-first AI assistant that reduces context switching, protects sensitive analysis from cloud exposure, and turns raw CVE identifiers into structured defensive guidance.

By combining public vulnerability data, optional enrichment, local LLM reasoning, and operator-focused workflow design, the project offers a strong fit for Black Hat Arsenal and for modern defensive teams that want practical AI support without giving up data control.

Repository: `HTTPS://GITHUB.COM/EMR4H/CVERESPONDERAI`